

Laboratorio | Inyección SQL



Bypass de Autenticación

Aprendí que un atacante puede saltarse el login de una aplicación inyectando caracteres especiales como '#' en el campo de usuario, lo que manipula la consulta SQL y elimina la verificación de contraseña, dando acceso sin credenciales válidas.

Inyección SQL Basada en UNION

Aprendí que usando el operador UNION se pueden combinar consultas maliciosas con las originales para extraer datos de otras tablas, siempre que se iguale el número de columnas y se identifiquen cuáles muestran información en pantalla.

Inyección SQL Basada en Errores

Aprendí que cuando una aplicación muestra mensajes de error detallados, un atacante puede provocar errores intencionales usando funciones como `extractvalue()` para que el propio mensaje revele nombres de tablas, columnas o datos sensibles.

Inyección SQL Ciega Booleana

Aprendí que aunque una aplicación no muestre errores ni datos, si su comportamiento cambia según una condición verdadera o falsa, un atacante puede hacer preguntas de sí/no a la base de datos y reconstruir información carácter por carácter.

Inyección SQL Ciega Basada en Tiempo

Aprendí que cuando la aplicación no da ninguna pista visual, el tiempo de respuesta del servidor se convierte en la única señal, usando funciones como `SLEEP()` para deducir información según si la página tarda o responde de inmediato.

Inyección SQL en Modificación \

Aprendí que las sentencias UPDATE también son vulnerables a inyección, y que un atacante puede modificar campos adicionales, cambiar la contraseña de todos los usuarios, o darse privilegios de administrador simplemente manipulando los valores enviados en un formulario de edición.